TRƯỜNG ĐẠI HỌC PHENIKAA
TRƯỜNG CÔNG NGHỆ THÔNG TIN
----------oOo----------

BÁO CÁO BÀI TẬP LỚN
CHỦ ĐỀ 4: DỰ ÁN FUZZING
PHÂN TÍCH VÀ KIỂM THỬ AN TOÀN BỘ PHÂN TÍCH CÚ PHÁP GÓI TIN NHỊ PHÂN FZP1
(BLACK-BOX VS GREYBOX VS WHITE-BOX CONCOLIC SMT Z3)

BIÊN BẢN KIỂM THỬ AN TOÀN BỘ NHỚ VÀ KIỂM CHỨNG HÌNH THỨC

Học phần:	CSE703093 – An toàn phần mềm
Lớp học phần:	An toàn phần mềm
Nhóm học phần:	Nhóm 11
Sinh viên thực hiện:	1. Lưu Đức Hiệp — 23010437 (Nhóm trưởng) 2. Hà Nguyễn Trúc Linh — 23010506 (Thành viên)
Giảng viên hướng dẫn:	ThS. Vũ Quang Dũng
Kho lưu trữ GitHub:	https://github.com/bachiep/ATPM-Nhom11-ChuDe4-Fuzzing
Thời gian thực hiện:	Hà Nội — Tháng 10, năm 2026

1. Thông tin đợt kiểm thử

Đơn vị thực hiện: Nhóm 11 — Học phần: CSE703093 (An toàn phần mềm) — Giảng viên: ThS. Vũ Quang Dũng

Thời gian kiểm thử: Tháng 10/2026 (Nghiệm thu toàn diện trước khi bàn giao đồ án)

Mã commit ghi nhận: e719c9b, nhánh main (https://github.com/bachiep/ATPM-Nhom11-ChuDe4-Fuzzing)

Bảng 1.1. Phân công trách nhiệm kiểm thử và phụ trách kỹ thuật:

Thành viên	Mã sinh viên	Phần phụ trách chính	Tỷ lệ đóng góp
Lưu Đức Hiệp (Trưởng nhóm)	23010437	Kiến trúc FZP1, Động cơ Fuzzing Black-box & Greybox, Thực nghiệm 30 Trials Benchmark, Phân tích số liệu và chu trình tiến hóa 4 mốc	50%
Hà Nguyễn Trúc Linh (Thành viên)	23010506	Bảng đặc tả SSOT Excel 10 sheet, Mô hình Kripke/CTL, Động cơ White-box Concolic SMT Z3, Phân tích mã nguồn C & Bản vá CERT C	50%

Đối tượng kiểm thử gồm: (1) Mã nguồn C v0, v0.1, v0.2, v1 trong source/; (2) Bộ động cơ Fuzzing ch4_dynafuzz_fzp1.py; (3) Tệp đặc tả SSOT 10 sheet Nhom11_FZP1_Fuzzing_Spec.xlsx; (4) Bộ kiểm thử tự động tests/; (5) Kịch bản thẩm định scripts/verify_project.py.

2. Môi trường và phương pháp thực hiện

2.1. Cấu hình môi trường kiểm thử

Hệ điều hành	Windows 11 Pro 64-bit (Build 22631) & Ubuntu 22.04 LTS (WSL2)
Kiến trúc vi xử lý	x86_64 (64-bit Little-Endian)
Trình biên dịch C	GCC 15.2.0 (MinGW-w64 UCRT64 với -fstack-protector-all) & Clang 18.1 (-fsanitize=address)
Môi trường Python	Python 3.13.7 64-bit
Bộ giải hình thức SMT	Microsoft Z3 SMT Solver v4.13.0 (qua z3-solver API)
Khung kiểm thử tự động	PyTest 9.1.1 (14/14 test cases pass)
Tệp đặc tả SSOT	Nhom11_FZP1_Fuzzing_Spec.xlsx (10 sheet chuẩn SecLabFramework Tab Ch6)

2.2. Lệnh biên dịch và kiểm thử thực tế

Biên dịch mã C có kích hoạt giám sát ô nhớ AddressSanitizer (ASan):

```
gcc -fsanitize=address -O0 -g source/fzp1_parser_v0.c -o source/fzp1_parser_v0_asan
gcc -fsanitize=address -O0 -g source/fzp1_parser_v1.c -o source/fzp1_parser_v1_asan
```

Biên dịch mã C với bảo vệ Stack Canary trên môi trường Windows:

```
gcc -Wall -Wextra -O0 -g -fstack-protector-all source/fzp1_parser_v0.c -o
source/fzp1_parser_v0.exe
gcc -Wall -Wextra -O0 -g -fstack-protector-all source/fzp1_parser_v1.c -o
source/fzp1_parser_v1.exe
```

Chạy bộ kiểm thử tự động toàn diện PyTest:

```
pytest tests/ -v
```

Chạy kịch bản thẩm định độc lập 8 khâu dự án:

```
python scripts/verify_project.py
```

3. Quy ước đánh giá kết quả

Đạt (PASS)	Kết quả thực tế khớp 100% với hành vi mong đợi (Đối với v0: tái hiện chính xác lỗi ô nhớ và mã lỗi OS; đối với v1: từ chối an toàn mã 2, không sập ô nhớ, ASan 0 findings).
Không đạt (FAIL)	Kết quả thực tế khác với mong đợi hoặc bản vá v1 vẫn bị sập ô nhớ.
Bảo đảm liêm chính	Toàn bộ số liệu 30 trials, time-to-first-crash và chu trình tiến hóa đều được trích xuất từ dữ liệu thô (.json), không sử dụng số liệu ngụy tạo.

4. Kết quả kiểm thử chi tiết

4.1. Kiểm thử mã nguồn C & Bắt lỗi động AddressSanitizer

Bảng 4.1. Kết quả kiểm thử 3 lỗ hổng ô nhớ kinh điển và bản vá CERT C:

Mã ca	Lỗ hổng & Đối tượng	Đầu vào / Vector kiểm thử	Kết quả ghi nhận (v0 vs v1)	Đánh giá
TC-C-01	CWE-121: Stack Buffer Overflow (parse_fzp1_payload)	Gói tin 73B (L=64 > 16B) crashes/iter1_cwe121_crash.bin	v0: Sập Canary 0xC0000409, ASan [f3] v1: Từ chối an toàn mã 2 (CERT STR31-C)	Đạt

Mã ca	Lỗ hổng & Đối tượng	Đầu vào / Vector kiểm thử	Kết quả ghi nhận (v0 vs v1)	Đánh giá
TC-C-02	CWE-415: Double Free (close_fzp1_session)	Gói tin 13B (L=4, CMD=0xFF) crashes/iter2_cwe415_crash.bin	v0: Sập Heap 0xC0000374, ASan Double Free v1: Gán NULL, Idempotent dọn an toàn	Đạt
TC-C-03	CWE-416: Use-After-Free (release_fzp1_stream)	Gói tin 13B (L=4, CMD=0xFE) crashes/iter3_cwe416_crash.bin	v0: Sập Access Violation 0xC0000005, ASan [fd] v1: Callback trước free, triệt tiêu con trỏ	Đạt
TC-C-04	Kiểm soát Magic Header (validate_fzp1_magic)	Magic 'BAD1' thay vì 'FZP1'	v0: Trả về -1 v1: Từ chối an toàn mã 2	Đạt
TC-C-05	Kiểm soát XOR Checksum (compute_xor_checksum)	Checksum 0xAA (sai khác)	v0: Trả về -2 v1: Từ chối an toàn mã 2	Đạt
TC-C-06	Kiểm soát kích thước tối thiểu	Gói tin cụt 8 bytes (< 9B)	v0: Trả về -1 v1: Từ chối an toàn mã 2	Đạt

4.2. Kết quả kiểm thử tự động toàn diện PyTest (14/14 Tests)

Kết quả thực thi tự động qua lệnh pytest tests/ -v:

• 10/10 Test cases đơn vị (tests/test_fzp1_parser.py): Xác thực đầy đủ bóc tách gói tin, chốt chặn Magic, Checksum, kích thước tối thiểu và phản hồi từ chối an toàn.
• 4/4 Test cases tiến hóa đa phiên bản (tests/test_fzp1_evolution.py): Kiểm chứng sự suy giảm crash theo đúng quy trình từ v0 (90 crashes) -> v0.1 (58) -> v0.2 (22) -> v1 (0 crash).
• Tổng hợp: 14 passed in 2.37s (Đạt tỷ lệ vượt qua 100%).

4.3. Kiểm tra Suy luận Hình thức SMT/Z3 Bit-Vector

Bảng 4.2. Đánh giá tính thỏa mãn ràng buộc đường đi (Path Constraints) trên Z3 SMT Solver:

Mã ca	Mệnh đề logic SMT Z3	Mô hình v0	Mô hình v1	Thời gian giải
TC-SMT-01	sym_magic == 'FZP1' (Magic header hợp lệ)	SAT	SAT	1.2 ms

Mã ca	Mệnh đề logic SMT Z3	Mô hình v0	Mô hình v1	Thời gian giải
TC-SMT-02	sym_len > 16 ^ sym_chk == XOR(payload) (Tràn Stack CWE-121)	SAT (Sinh PoC)	UNSAT (Đã chặn)	6.98 ms
TC-SMT-03	payload[0] == 0xFF ^ abort_session (Double Free CWE-415)	SAT (Kích hoạt)	UNSAT (Idempotent)	3.4 ms
TC-SMT-04	payload[0] == 0xFE ^ stream_reset (Use-After-Free CWE-416)	SAT (Dangling)	UNSAT (Safe cleanup)	2.9 ms

4.4. Kiểm chứng mô hình trạng thái Kripke / CTL

Mô hình Kripke 4 trạng thái (st_idle, st_magic_ok, st_checksum_ok, st_conflict) được kiểm chứng trên SecLabFramework Tab Ch6:

1. Deadlock-free AG(EF st_idle): ĐÚNG (True) — Hệ thống không có trạng thái bế tắc. 2. Thuộc tính an toàn AG(!violation): SAI (False) trên v0 (tồn tại đường đi st_idle -> st_magic_ok -> st_conflict khi L>16); ĐÚNG (True) trên v1 khi thêm tiền điều kiện an toàn CERT C. 3. Khẳng định nguy cơ EF(violation): ĐÚNG (True) trên v0.

4.5. Đối chuẩn thực nghiệm Fuzzing 30 Trials

Dữ liệu trích xuất từ 30 lượt chạy độc lập (results/data_raw/aggregated_results.json):

Trường phái Fuzzing	Tỷ lệ tìm Crash	Time-to-Crash Trung vị	Tốc độ Exec/s	Kết luận học thuật
Black-box Fuzzing (Ngẫu nhiên)	0.0% (0/30)	Timeout (>60s)	80.8 lượt/s	Bị chặn bởi rào cản xác suất P ≈ 9.09 x 10^-13
Greybox Fuzzing (Coverage-guided)	46.67% (14/30)	2.1568 giây	79.05 lượt/s	Ghim Magic 'FZP1', dò đột biến Checksum 1/256
White-box Concolic (SMT Z3)	100.0% (30/30)	0.2056 giây	4.90 lượt/s	Giải trực tiếp Bit-Vector trong 6.98 ms

4.6. Chu trình tiến hóa kiểm thử và vá lỗi đa giai đoạn

Thực nghiệm kiểm chứng trên 500 gói tin kiểm thử đa dạng kích hoạt cả 3 nhóm lỗi:

• Mốc 1 (v0 - Ban đầu): Ghi nhận 90 crashes / 250 lượt (36.0%) — Sập Stack Canary CWE-121.
• Mốc 2 (v0.1 - Sau vá STR31-C): Đổi Seed bơm mã 0xFF -> Giảm còn 58 crashes / 250 lượt (23.2%) — Sập Double Free CWE-415.
• Mốc 3 (v0.2 - Sau vá tiếp MEM31-C): Đổi Seed bơm mã 0xFE -> Giảm còn 22 crashes / 250 lượt (8.8%) — Sập Use-After-Free CWE-416.
• Mốc 4 (v1 - Hoàn thiện 3 chuẩn CERT C): Seed hỗn hợp 500 gói tin -> 0 CRASH (0.0%), an toàn tuyệt đối 100%.

5. Đối chiếu trước và sau sửa lỗi (Chuẩn Table 2)

Mã CWE & Chuẩn CERT	Vị trí trong mã C	Trạng thái ban đầu (v0)	Trạng thái đã vá (v1)	Công cụ xác minh
CWE-121 CERT STR31-C	parse_fzp1_payload() fzp1_parser_v0.c:149	Stack buffer overflow khi L>16; sập Canary 0xC0000409	Chặn trên cứng L<=16, bộ đệm 17B null-terminated; từ chối an toàn mã 2	Clang ASan [f3], PyTest
CWE-415 CERT MEM31-C	close_fzp1_session() fzp1_parser_v0.c:93	Double Free khi nhận CMD 0xFF; sập Windows Heap 0xC0000374	Gán ngay ptr = NULL; hàm dọn dẹp Idempotent an toàn tuyệt đối	Windows Heap Manager, PyTest
CWE-416 CERT MEM30-C	release_fzp1_stream() fzp1_parser_v0.c:122	Use-After-Free khi nhận CMD 0xFE; sập Access Violation 0xC0000005	Gọi callback trước, free và gán NULL sau; triệt tiêu Dangling Pointer	Clang ASan [fd], PyTest
Tỷ lệ sống sót Fuzzing	Toàn bộ bộ phân tích C	90 crashes / 250 gói tin (36.0%)	0 crashes / 500 gói tin (100% PASS)	Coverage-guided Fuzzer

6. Kết luận đợt kiểm thử

Toàn bộ 8 khâu kiểm định của đồ án đã được xác nhận độc lập qua script tự động verify_project.py:

1. Toolchain & Phụ thuộc: ĐẠT CHUẨN (PASS)
2. Unit Test PyTest (14/14): ĐẠT CHUẨN (PASS)
3. Đặc tả Excel 10 Sheet (SSOT): ĐẠT CHUẨN (PASS)
4. 3 Lỗ hổng Bộ nhớ & Bản vá CERT C: ĐẠT CHUẨN (PASS)
5. Phân tích tĩnh Cppcheck (Minh chứng False Negative): ĐẠT CHUẨN (PASS)
6. Suy luận hình thức SMT Z3: ĐẠT CHUẨN (PASS)
7. Benchmark 30 Trials & Biểu đồ: ĐẠT CHUẨN (PASS)
8. Toàn vẹn Mã băm SHA-256 (28 tệp cốt lõi): ĐẠT CHUẨN (PASS)

ĐÁNH GIÁ: KẾT LUẬN CHUNG: ĐỒ ÁN ĐẠT CHUẨN 100% — SẴN SÀNG NGHIỆM THU THEO YÊU CẦU CỦA GIẢNG VIÊN.

7. Ký xác nhận đợt kiểm thử

Hà Nội, ngày 29 tháng 10 năm 2026

NGƯỜI KIỂM THỬ M1 & BENCHMARK	NGƯỜI KIỂM THỬ M2 & ĐẶC TẢ SSOT
(Ký và ghi rõ họ tên)	(Ký và ghi rõ họ tên)
(Đã ký điện tử)	(Đã ký điện tử)
Lưu Đức Hiệp	Hà Nguyễn Trúc Linh
(Nhóm trưởng — Đóng góp 50%)	(Thành viên — Đóng góp 50%)